

Security+ 4.8 · Incident Planning

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 4.8** —
Incident Planning (6:50) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Incident planning involves structured exercises and analysis to prepare for and respond to security incidents. Tabletop exercises are discussion-based sessions that train decision-makers without real-world impact. Simulations introduce simulated failures to test response capabilities. Root Cause Analysis (RCA) identifies the underlying reason for an incident, not just symptoms. Documentation and playbooks provide predefined procedures for specific incident types, such as ransomware or phishing.

High-Yield Core Concepts Tested on Exam

- Tabletop exercise: discussion-based, no real impact, trains decision-makers
- Simulation: simulated failure to test technical response
- Root Cause Analysis (RCA): identifies the true cause, not just symptoms
- Playbooks: predefined procedures for specific incident types (e.g., ransomware, phishing)
- Documentation: essential for incident response consistency and improvement

Exam Tips & Classic Scenarios

- If the scenario mentions a simulated exercise without real impact, choose tabletop.
- RCA focuses on the 'why' behind an incident, not the 'what'.

Typical Exam Scenario: A company gathers its incident response team to walk through a ransomware attack scenario in a meeting room, discussing roles and actions without touching any systems. This is a tabletop exercise.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 4.8 — Incident Planning)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. According to NIST, what is the first phase of the incident response cycle?

- A)** Detection and Analysis
- B)** Preparation
- C)** Containment
- D)** Recovery

2. Corporate scenario (Incident Planning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'Tabletop: the incident 'board game' — trains without real impact'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Tabletop: the incident 'board game' — trains without real impact...

3. Corporate scenario (Incident Planning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'RCA: the ROOT cause (the why), not the symptom'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: RCA: the ROOT cause (the why), not the symptom...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (Incident Planning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'simulated exercise without real impact' = tabletop. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'simulated exercise without real impact' = tabletop...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Incident Planning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'company plays out the ransomware scenario in a discussion to test response' = tabletop. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'company plays out the ransomware scenario in a discussion to test response' = tabletop
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Incident Planning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'Tabletop: the incident 'board game' — trains without real impact'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Tabletop: the incident 'board game' — trains without real impact
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Incident Planning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'RCA: the ROOT cause (the why), not the symptom'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: RCA: the ROOT cause (the why), not the symptom...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Incident Planning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'simulated exercise without real impact'=tabletop. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'simulated exercise without real impact'=tabletop...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Incident Planning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'company plays out the ransomware scenario in a discussion to test response' = tabletop. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'company plays out the ransomware scenario in a discussion to test response' = tabletop
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Incident Planning): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 4.8), an analyst evaluates the following technical requirement: 'Tabletop: the incident 'board game' — trains without real impact'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Tabletop: the incident 'board game' — trains without real impact...
- D)** Allow shared access among administrators with generic credentials



COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Preparation.

✓ **Why it is correct:** The correct answer is 'Preparation'. According to NIST SP 800-61 (Computer Security Incident Handling Guide), the incident response cycle consists of four phases: Preparation; Detection and Analysis; Containment, Eradication, and Recovery; and Post-Incident Activity. The first phase, Preparation, is fundamental and occurs before any incident happens. It involves establishing policies, procedures, team training, acquiring tools (SIEM, EDR, forensics), defining communication channels, and creating response plans. Without adequate preparation, subsequent phases are compromised. CompTIA Security+ emphasizes that preparation is the foundation for effective response and must be continuous, including exercises and simulations.

✗ **Why the others are wrong:**

- *Detection and Analysis:* This is the second phase of the NIST incident response cycle. It occurs after preparation and involves monitoring, identifying, and validating the occurrence of an incident, as well as analyzing its scope and impact. Although crucial, it is not the first phase because it depends on resources, procedures, and training established during preparation. Detection and analysis can only be effective if there is a prepared foundation to collect logs, correlate events, and interpret alerts.
- *Containment:* Containment is part of the third phase of the cycle (Containment, Eradication, and Recovery). Its goal is to limit damage and prevent the spread of the incident by isolating affected systems. However, containment can only be executed after the incident has been detected and analyzed, and it depends on plans and resources defined in the preparation phase. Therefore, it is not the first phase but a reactive step that occurs during the incident.
- *Recovery:* Recovery also integrates the third phase of the cycle, after containment and eradication. It consists of restoring affected systems and services to normal operation, validating that the threat has been eliminated, and monitoring to ensure no reinfection. Like containment, recovery is a step after detection and analysis and depends on prior preparation, such as backups and continuity plans. It is not the first phase of the incident response cycle.

2) D — Implement the corresponding solution: Tabletop: the incident 'board game' — trains without real impact....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Planning): Tabletop: the incident 'board game' — trains without real impact. This correctly describes tabletop exercises, which are discussion-based sessions where team members walk through simulated incident scenarios to test response plans without affecting actual systems.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

3) B — Implement the corresponding solution: RCA: the ROOT cause (the why), not the symptom....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Planning): RCA: the ROOT cause (the why), not the symptom. Root Cause Analysis (RCA) is a systematic process for identifying the underlying reasons for an incident, focusing on the fundamental cause rather than superficial symptoms, to prevent recurrence.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: 'simulated exercise without real impact' = tabletop....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Planning): 'simulated exercise without real impact' = tabletop. A tabletop exercise is a discussion-based session where team members simulate an emergency scenario to evaluate incident response plans, without affecting real systems.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: 'company plays out the ransomware scenario in a discussion to test response' = tabletop.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Planning): 'company plays out the ransomware scenario in a discussion to test response' = tabletop. A tabletop exercise is a discussion-based session where team members simulate an emergency scenario to test response plans.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: Tabletop: the incident 'board game' — trains without real impact.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Planning): Tabletop: the incident 'board game' — trains without real impact. Tabletop exercises simulate incident response scenarios to validate plans and roles without disrupting production.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: RCA: the ROOT cause (the why), not the symptom....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Planning): RCA: the ROOT cause (the why), not the symptom. Root Cause Analysis (RCA) is a method to identify the fundamental reason for an incident, rather than just addressing symptoms, to prevent recurrence.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: 'simulated exercise without real impact'=tabletop....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Planning): 'simulated exercise without real impact'=tabletop.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 'company plays out the ransomware scenario in a discussion to test response' = tabletop.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Planning): 'company plays out the ransomware scenario in a discussion to test response' = tabletop. A tabletop exercise is a discussion-based session where team members simulate an emergency scenario to test response plans.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Tabletop: the incident 'board game' — trains without real impact...

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 4.8 (Incident Planning): Tabletop: the incident 'board game' — trains without real impact. A tabletop exercise is a discussion-based session where key stakeholders walk through a simulated incident scenario to test the incident response plan, identify gaps, and improve coordination, all without affecting real systems. It is a cost-effective way to validate plans and train personnel.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.